



logo_unicam.png

Università degli Studi di Camerino

SCUOLA DI SCIENZE E TECNOLOGIE

Corso di Laurea in Informatica (Classe L-31)

**LogTrace: Implementazione di un Sistema
per la gestione e il monitoraggio degli Audit
Logs in SIGMA S.p.A**

Laureando

Nicola Capancioni

Matricola 122631

Relatore

Prof.ssa Barbara Re

Correlatore

Dott. Vincenzo Ferraro

Indice

1	Introduzione	3
1.1	Motivazione	3
1.2	Obiettivi	3
2	Fondamenti della Gestione dei Log in Ambito Aziendale	4
2.1	Log Collection	4
2.2	Normativa ISO/IEC 27001 e conformità	4
2.3	Direttiva NIS2 e Quadro Normativo Nazionale (ACN)	5
2.4	Immutabilità del dato e integrity checking	5
2.5	Retention dei log e policy aziendali	5
2.6	Ruolo del DPO e aspetti di privacy	6
3	Architettura di Logging in Windows Server e Strategie di Auditing	7
3.1	Il Framework Windows Event Log	7
3.2	Struttura e Anatomia dell'Evento EVTX	7
3.3	Tassonomia dei Canali di Logging	8
3.3.1	System Log	8
3.3.2	Application Log	9
3.3.3	Security Log	9
3.4	Windows Event Viewer	9
4	Analisi dei Software di Log Managment	11
4.1	Metodologia e selezione di confronto	11
4.2	Soluzioni Open Source: vantaggi e limiti	11

1. Introduzione

Oggi le realtà aziendali, si trovano a fronteggiare quotidianamente minacce informatiche sempre più evolute, che mettono a dura prova la riservatezza, la disponibilità e l'integrità dei dati.

La rapida diffusione del lavoro ibrido e dei servizi cloud ha esteso notevolmente il perimetro di sicurezza da difendere: in questo scenario, disporre di un tracciamento affidabile e completo delle attività non è più un'opzione, ma un requisito indispensabile per garantire la sicurezza dell'infrastruttura.

Questo capitolo introduttivo illustra le motivazioni che hanno guidato il progetto e delinea una panoramica del presente lavoro di tesi.

1.1 Motivazione

La gestione centralizzata dei log è cruciale: questi sono l'unica fonte oggettiva per comprendere gli eventi di un sistema informativo. Essi sono fondamentali sia per risposte reattive, come l'incident response e l'analisi forense, sia per azioni proattive, inclusi il rilevamento di anomalie e attività sospette. Per essere efficaci, i log devono essere raccolti, conservati e analizzati seguendo criteri precisi, considerando sia gli aspetti tecnici che normativi.

1.2 Obiettivi

Questa tesi approfondisce le sfide e le soluzioni del log management, esaminando strumenti open source e piattaforme commerciali. L'obiettivo pratico è presentare un'architettura sviluppata specificamente per la raccolta, il filtraggio e la visualizzazione dei log di audit in un contesto aziendale, utilizzando tecnologie che garantiscano affidabilità, scalabilità e facilità di integrazione, così da assicurare un monitoraggio efficace e una gestione sicura dei dati.

2. Fondamenti della Gestione dei Log in Ambito Aziendale

2.1 Log Collection

La raccolta dei log (log collection) rappresenta uno strumento fondamentale per garantire la sicurezza, la tracciabilità e la trasparenza delle operazioni svolte all'interno di un'infrastruttura informatica. In ambito aziendale, essa assume un'importanza strategica, poichè consente agli amministratori di sistema di monitorare in modo puntuale le azioni eseguite da dipendenti, fornitori e utenti che interagiscono con le risorse informatiche aziendali. Attraverso la log collection è possibile identificare comportamenti anomali, rilevare potenziali minacce alla sicurezza, supportare attività di audit e fornire elementi utili per l'analisi forense in caso di incidente. Inoltre, essa contribuisce al rispetto delle normative vigenti in materia di sicurezza e protezione dei dati, supportando l'organizzazione nella definizione di policy interne più efficaci e trasparenti.

2.2 Normativa ISO/IEC 27001 e conformità

La normativa ISO/IEC 27001 [Iso] costituisce lo standard di riferimento internazionale per la gestione della sicurezza delle informazioni (Information Security Management System – ISMS). Essa definisce i requisiti per la creazione, l'implementazione, il mantenimento e il miglioramento continuo di un sistema di gestione della sicurezza delle informazioni.

In particolare, il controllo **8.15 – Raccolta dei Log**, introdotto nella revisione 2022 dello standard, non si limita a prescrivere la mera archiviazione degli eventi, ma impone requisiti stringenti sulla protezione degli stessi contro la manomissione (tampering) e l'accesso non autorizzato. La conformità a tale requisito, in ambito Enterprise, richiede l'adozione di misure tecniche avanzate, affinché i log acquisiscano valore probatorio e forense. Ciò implica la definizione di procedure chiare per la gestione dell'intero ciclo di vita del dato, garantendo in particolare la protezione contro modifiche non autorizzate, una conservazione per un periodo adeguato (retention) e la possibilità di effettuare verifiche puntuali di integrità.

2.3 Direttiva NIS2 e Quadro Normativo Nazionale (ACN)

Parallelamente agli **standard di riferimento** internazionali, il contesto della sicurezza informatica è oggi fortemente regolato da normative che elevano il log management da *best practice* a obbligo legale indispensabile per la continuità operativa. La **Direttiva (UE) 2022/2555 (NIS2)** rappresenta l'evoluzione della strategia europea di cybersicurezza, estendendo gli obblighi a nuovi settori critici (es. energia, trasporti, sanità). L'elemento cardine della direttiva è il passaggio da un approccio reattivo a uno proattivo nella gestione del rischio: essa impone rigorose finestre temporali per la notifica degli incidenti (pre-allarme entro 24 ore, notifica completa entro 72 ore). In questo contesto, l'adozione di un sistema di logging centralizzato non è solo una misura di sicurezza, ma l'unico strumento che permette di ricostruire la catena degli eventi con la tempestività richiesta dalla legge per l'*incident reporting*.

A livello nazionale, l'**Agenzia per la Cybersicurezza Nazionale (ACN)** ha il compito di recepire tali direttive e tradurle in misure tecniche operative, specialmente per i soggetti inclusi nel Perimetro di Sicurezza Nazionale Cibernetica (PSNC). Mentre la NIS2 pone l'obbligo di risultato, l'ACN definisce gli standard architetturali e i protocolli di scambio dati necessari per l'interazione con lo CSIRT Italia. Il sistema LogTrace è stato progettato proprio per soddisfare questi requisiti tecnici attuativi, garantendo un flusso di audit granulare e immutabile che risponde agli standard di qualità del dato richiesti per la cooperazione con le autorità nazionali.

2.4 Immutabilità del dato e integrity checking

Un elemento essenziale in un sistema di log collection efficace è l'immutabilità del dato. I log, una volta raccolti e memorizzati, devono essere considerati come evidenze digitali e, in quanto tali, non devono poter essere modificati o eliminati, nemmeno dagli amministratori di sistema. Questa caratteristica garantisce l'affidabilità e l'integrità delle informazioni registrate. Per rafforzare ulteriormente tale requisito, è fondamentale implementare meccanismi di integrity checking, come l'utilizzo di funzioni crittografiche (es. hash, firme digitali) e database immutabili (come blockchain o tecnologie append-only). Tali tecnologie permettono di verificare che i dati non siano stati alterati nel tempo, rendendo possibile l'individuazione di manomissioni e assicurando la validità legale e forense delle informazioni raccolte.

2.5 Retention dei log e policy aziendali

La retention dei log fa riferimento al periodo di tempo durante il quale i dati di log devono essere conservati prima di essere eliminati o archiviati. La definizione di una log retention policy è una responsabilità cruciale per ogni organizzazione, in quanto impatta sia sulla conformità normativa sia sull'efficienza operativa. Tali policy devono tenere conto di diversi fattori, tra cui i requisiti di legge, le neces-

sità di auditing, le capacità infrastrutturali di storage e gli obiettivi aziendali. In generale, è consigliabile conservare i log per un periodo sufficiente a garantire la possibilità di investigare incidenti, supportare audit periodici e fornire tracciabilità delle operazioni sensibili.

2.6 Ruolo del DPO e aspetti di privacy

Il Responsabile della Protezione dei Dati (Data Protection Officer - DPO), figura obbligatoria per determinati titolari ai sensi degli artt. 37-39 del Regolamento (UE) 2016/679 (GDPR), riveste un ruolo cruciale di consulenza e sorveglianza nelle architetture di Log Management. Poiché i log di audit contengono inevitabilmente dati personali (es. indirizzi IP, username, timestamp di attività), il loro trattamento deve essere attentamente bilanciato.

Pertanto, il DPO vigila affinché il sistema rispetti i principi fondamentali sanciti dall'art. 5 del GDPR, in particolare:

- **Minimizzazione dei dati:** Assicurare che vengano raccolti solo i log strettamente necessari per le finalità di sicurezza, evitando la registrazione indiscriminata di attività utente non pertinenti.
- **Limitazione della finalità:** Garantire che i dati raccolti per scopi di auditing e sicurezza vengano utilizzati solo per tali finalità, evitando impieghi impropri (es. monitoraggio delle prestazioni lavorative), salvo specifici accordi sindacali o normative di settore.

3. Architettura di Logging in Windows Server e Strategie di Auditing

3.1 Il Framework Windows Event Log

Il monitoraggio degli eventi nei moderni sistemi operativi Microsoft si basa su un'infrastruttura centralizzata e strutturata nota come **Windows Event Log**. Questo sottosistema rappresenta il meccanismo standard attraverso il quale il sistema operativo, i servizi di sistema e le applicazioni registrano occorrenze significative, fornendo agli amministratori una visione cronologica e dettagliata dello stato della macchina. Con l'avvento di Windows Server 2008 e Windows Vista, Microsoft ha introdotto una profonda revisione di questo sistema, migrando dal formato legacy (`.evt`) al formato **EVTX** (*Windows XML Event Log*). A differenza dei tradizionali file di log testuali (comuni ad esempio in ambiente Unix/Linux con `syslog`), il formato `.evtx` è un file binario proprietario che incapsula i dati in struttura **XML**.

Il funzionamento del framework si basa sul concetto di **Event Providers**. Un *Provider* è il componente software (driver, servizio o kernel) che genera l'evento. Il servizio di sistema *Windows Event Log Service* si occupa di intercettare questi eventi, formattarli secondo lo schema XML e scriverli nel canale (*Channel*) appropriato su disco, garantendo la persistenza e l'integrità sequenziale delle registrazioni.

3.2 Struttura e Anatomia dell'Evento EVTX

La struttura XML di un evento EVTX è rigorosamente bipartita per separare l'indicizzazione (gestita dal sistema operativo) dal contenuto informativo (gestito dall'applicazione).

- **System Section (Metadati e Contesto Infrastrutturale):**

Rappresenta l'intestazione standard dell'evento, conforme a uno schema globale definito da Microsoft. Questa sezione è presente in modo identico per ogni tipologia di log e contiene i campi necessari al sistema operativo per l'indicizzazione, il filtraggio veloce e la correlazione temporale. Gli elementi costitutivi essenziali sono:

- **Provider:** Identifica univocamente la fonte generatrice (es. *Microsoft-Windows-Security-Auditing*) tramite Nome e GUID.

- **EventID**: Il codice numerico che classifica la tipologia dell'evento.
 - **Level, Task, Opcode, Keywords**: Metadati tassonomici che definiscono la gravità, la categoria operativa e l'azione specifica intrapresa.
 - **TimeCreated**: Il timestamp ad alta precisione (SystemTime) che colloca l'evento nella cronologia globale.
 - **Execution**: Fornisce il contesto di esecuzione a basso livello, specificando il **ProcessID** (PID) e il **ThreadID** (TID) che hanno originato la registrazione.
 - **Channel**: Il canale logico di appartenenza (es. Security, System).
 - **Security**: Identifica il contesto di sicurezza (User SID) sotto il quale è stata eseguita l'operazione (spesso *SYSTEM* o l'utente loggato).
- **EventData Section (Payload Semantico Variabile)**:
 Costituisce il corpo variabile dell'evento. A differenza della sezione *System*, questa parte non segue uno schema globale fisso, ma una struttura definita dinamicamente dal Provider specifico per quel determinato **EventID**. Tecnicamente, si presenta come una collezione di elementi **<Data>** identificati da un attributo **Name**. Questa sezione ospita le informazioni forensi critiche necessarie per ricostruire l'accaduto nel dettaglio, quali:
 - Identificativi dei soggetti coinvolti (es. *TargetUserName*, *TargetSid*).
 - Informazioni di rete (es. *IpAddress*, *IpPort*).
 - Oggetti del sistema manipolati (es. *ObjectName*, *ProcessName*, *ServiceFileName*).
 - Risultati specifici delle operazioni (es. codici di errore esadecimali in caso di fallimento, *FailureReason*).

È in questa sezione che risiede il valore investigativo del log, mentre la sezione *System* funge da "busta" per la consegna e l'archiviazione.

3.3 Tassonomia dei Canali di Logging

L'architettura organizza i log in contenitori logici definiti canali. I tre pilastri fondamentali per l'amministrazione di un ambiente Windows Server sono:

3.3.1 System Log

Raccoglie gli eventi generati dai componenti in *kernel-mode* e dai servizi critici di Windows. In questo canale vengono registrati i cambiamenti di stato dei driver, gli errori del file system e le operazioni del *Service Control Manager* (SCM), come l'avvio, l'arresto o il crash imprevisto dei servizi di sistema.

3.3.2 Application Log

È il collettore per gli eventi generati dalle applicazioni in *user-mode*. La semantica di questi eventi è definita dagli sviluppatori del software stesso (es. Microsoft SQL Server, IIS o agenti di sicurezza terzi). Questo canale è utilizzato per tracciare errori applicativi, warning o informazioni operative non legate al sistema operativo sottostante.

3.3.3 Security Log

Rappresenta il componente nevralgico per l'auditing. A differenza degli altri canali, l'accesso e la scrittura in questo log sono protetti e gestiti direttamente dal **LSASS** (*Local Security Authority Subsystem Service*).

Questo canale registra gli eventi di **Audit**, classificati in:

- **Audit Success:** Conferma che un'operazione che richiede privilegi (es. accesso a un file, login) è stata eseguita.
- **Audit Failure:** Segnala che un tentativo di eseguire un'operazione è stato bloccato dal sistema per mancanza di permessi o credenziali errate.

L'accesso in lettura a questo file richiede privilegi amministrativi specifici (**SeSecurityPrivilege**), rendendolo la fonte primaria e più sicura per la ricostruzione di incidenti.

3.4 Windows Event Viewer

Il sistema operativo Windows offre un'interfaccia per l'interazione con il sottosistema di logging, rappresentata dall'*Event Viewer* e accessibile tramite la console di gestione `eventvwr.msc`.

Si tratta di uno snap-in della *Microsoft Management Console* (MMC) che funge da front-end grafico per il servizio di logging. Attraverso questo strumento, gli amministratori di sistema possono navigare tra i vari canali (Application, Security, System), filtrare gli eventi in base all'ID o alla gravità, e ispezionare i dettagli di ogni singola registrazione.

Sebbene l'Event Viewer sia uno strumento indispensabile per il *troubleshooting* locale e l'analisi forense su singole macchine, esso mostra evidenti limiti in scenari Enterprise distribuiti:

- **Assenza di Alerting Proattivo:** Lo strumento opera in modalità passiva. Non dispone di un motore nativo per l'invio di notifiche o allarmi in tempo reale (es. email o ticket) al verificarsi di eventi critici, lasciando l'infrastruttura esposta fino alla successiva ispezione manuale.
- **Analisi Reattiva e Post-Mortem:** È progettato per consultare i log *dopo* che il problema è stato segnalato dagli utenti, rendendo impossibile un approccio preventivo o l'intercettazione tempestiva di un attacco in corso.

- **Problemi di Retention e Sovrascrittura:** I file di log locali (EVTX) hanno una dimensione massima predefinita e utilizzano una logica circolare (*circular logging*). In server ad alto traffico, gli eventi più datati vengono sovrascritti rapidamente dai nuovi, causando la perdita definitiva di prove storiche fondamentali per l'auditing.
- **Vulnerabilità al Tampering:** Mantenere i log esclusivamente sulla macchina che li ha generati viola il principio di segregazione. Un attaccante che ottiene privilegi amministrativi può facilmente cancellare o alterare le tracce locali (*Clear Log*) per nascondere la propria attività, rendendo vana ogni indagine forense.

È proprio per superare queste criticità strutturali e per garantire la conformità ai requisiti normativi stringenti imposti dagli standard **ISO/IEC 27001** e dalla direttiva **NIS2**, che si rende necessaria l'adozione di un cambio di paradigma architetturale. L'implementazione di un sistema di *Centralized Log Management* (CLM), come quello proposto nel progetto **LogTrace**, risponde a questa esigenza disaccoppiando la fase di generazione del dato dalla sua conservazione e analisi. Tale approccio permette di trasformare i log da semplici file locali volatili a evidenze digitali sicure, immutabili e immediatamente correlabili.

4. Analisi dei Software di Log Management

In questo capitolo verranno analizzati i principali software di *Log Management* attualmente disponibili sul mercato, con riferimento alle loro capacità di *raccogliere, elaborare e visualizzare* dati provenienti da diversi sistemi informatici aziendali. Verrà inoltre descritta la metodologia adottata per valutare e selezionare la soluzione più adeguata, tenendo conto dei requisiti tecnici, organizzativi ed economici dell'azienda.

L'analisi comprende una comparazione tra i vari strumenti in termini di funzionalità, facilità di integrazione, scalabilità, costi di azione e gestione, nonché vantaggi e limitazioni di ciascuna soluzione. L'obiettivo è identificare il sistema di log management più efficace, sostenibile e coerente con le esigenze specifiche dell'ambiente aziendale considerato. Infine, viene presentata una sezione di confronto tra tali soluzioni e quella effettivamente implementata nel contesto aziendale in esame, al fine di evidenziare le motivazioni della scelta e le eventuali differenze riscontrate.

4.1 Metodologia e selezione di confronto

La selezione degli strumenti di *Log Management* si è basata su criteri di *funzionalità, scalabilità, facilità d'integrazione, costi e semplicità di utilizzo*. Sono stati inclusi software open source, scelti per la loro rilevanza nel settore e per la disponibilità di documentazione o supporto attivo.

Il confronto mira a valutare punti di forza e limiti di ciascuna soluzione, con particolare attenzione alla gestione di grandi volumi di log, all'efficienza operativa e alla compatibilità con strumenti di osservabilità moderni.

4.2 Soluzioni Open Source: vantaggi e limiti

Le soluzioni open source per il log management rappresentano una scelta sempre più diffusa grazie alla loro flessibilità, trasparenza e costo generalmente contenuto. Offrono la possibilità di personalizzare gli strumenti in base alle esigenze specifiche, favorendo l'integrazione con altre tecnologie e la collaborazione nella community. Tuttavia, queste soluzioni possono richiedere competenze tecniche più avanzate per la configurazione e la manutenzione, e talvolta presentano limiti in termini di supporto ufficiale e funzionalità enterprise rispetto alle alternative commerciali.

- *Logstash*: Logstash si configura come una pipeline open source per l'elaborazione dati lato server, è costruita su JVM (Java Virtual Machine) La sua funzione principale è raccogliere dati da una vasta gamma di sorgenti (come file, metriche di sistema o *code Redis*) attraverso plugin di input specifici. Successivamente, trasforma questi dati utilizzando plugin di filtro (come *grok* per il parsing o *mutate* per la modifica), rendendoli pronti per essere inviati a "destinazioni" finali quali Elasticsearch o Kafka, facilitandone così l'analisi e l'archiviazione. Fonte: sito web ufficiale di LogStash.
- *Graylog*: Graylog Open è una soluzione centralizzata per la gestione dei log, self-managed e open source (licenza SSPL), basata su MongoDB ed Elasticsearch. E' progettata per l'aggregazione e l'analisi dei dati di log, offrendo ricerche basate su Lucene e funzionalità di alerting e dashboarding in tempo reale, rendendola ideale per esplorare grandi volumi di dati. Fonte: sito web ufficiale di Graylog.
- *OpenObserve*: OpenObserve (O2) è una piattaforma di observability cloud-native per log, metriche, tracce, analytics e RUM (Real User Monitoring - Performance, Errors, Session Replay), progettata per operare su scala petabyte. Si distingue per la sua semplicità operativa e funge da sostituto diretto per Elasticsearch, integrando una propria interfaccia utente. Il suo vantaggio chiave è la notevole riduzione dei costi di storage dei log (fino a 140x) rispetto a Elasticsearch. Fonte: sito web ufficiale di OpenObserve.
- *Prometheus*: Prometheus, un progetto della Cloud Native Computing Foundation (CNCF), è un sistema di monitoraggio e alerting che raccoglie metriche da target configurati a intervalli. Si basa sul "pulling" di metriche da endpoint HTTP e le memorizza in un TSDB (Time Series Database) interno. Permette di valutare espressioni tramite PromQL, visualizzare i risultati e attivare alert con Alertmanager, per la rilevazione proattiva di problemi. Fonte: sito web ufficiale di Prometheus.
- *SigNoz*: SigNoz è una piattaforma open source per l'observability che si propone come alternativa unificata e strumenti commerciali come Datadog o New Relic. Utilizza OpenTelemetry per la raccolta standardizzata di metriche, tracce e log, garantendo una completa interoperabilità. Questa soluzione consente il monitoraggio delle performance delle applicazioni (APM), la gestione delle eccezioni e degli alert, centralizzando in modo efficiente tutti i dati di osservabilità per facilitare l'analisi e il troubleshooting in ambienti aziendali complessi. Fonte: sito web ufficiale di SigNoz.
- *Syslog-ng*: syslog-ng si presenta come lo "strumento multiuso" per la gestione dei log, è infatti capace di collezionare dati da qualsiasi sorgente tramite plugin di input. Permette di elaborare i log in tempo reale con moduli di parsing e funzioni di filtro/riscrittura, consentendo anche la correlazione. Infine, distribuisce i log a diverse destinazioni tramite plugin di output, come file o sistemi di analisi. Fonte: sito web ufficiale di syslog-ng.

- Grafana Loki: Grafana Loki è un sistema di aggregazione log orizzontalmente scalabile, ad alta disponibilità e multi-tenant, ispirato a Prometheus. E' molto 'cost-efficiente e facile da operare poich'è non indicizza il contenuto completo dei log, ma solo un set di etichette. I log sono archiviati in storage a basso costo, e interrogati tramite LogQL in base alle etichette.
Fonte: sito web ufficiale di Grafana Loki.
- Quickwit: Quickwit è un motore di ricerca e analytics cloud-native ottimizzato per log e tracce, progettato per operare direttamente su object storage (come S3) con ricerche sub-secondo e a scala petabyte. Scritto in Rust e basato sulla libreria Tantivy, si distingue per il suo formato file ottimizzato e la programmazione I/O intelligente che riducono i costi e aumentano il throughput. Offre indicizzazione schemaless e integrazione nativa con OpenTelemetry e Jaeger, facilitando il troubleshooting e la gestione di grandi volumi di dati di osservabilità con un'architettura disaccoppiata e stateless, ideale per il deployment su cloud o on-premise. Fonte: sito web ufficiale di Quickwit.
- SigLens: SigLens è una piattaforma di observability open source che mira a essere 100x più efficiente di Splunk. Si distingue per poter essere installato da un singolo binario capace di gestire log, metriche e tracce senza dipendenze esterne, semplificando notevolmente il deployment e la manutenzione rispetto a soluzioni più complesse come Elasticsearch. E progettata per processare grandi volumi di 'dati (fino a 8 TB/giorno su un laptop) e superare le lentezze di query di Grafana Loki, offrendo una soluzione unificata e performante.
Fonte: sito web ufficiale di SigLens.